République Algérienne Démocratique et Populaire
Ministère de l'Enseignement Supèrieur et de la Recherche Scientifique
USTHB
Département d'Informatique
Professeur H. NACER

Support de cours

Sécurité

Année Universitaire : 2025 / 2026

Chapitre 1

Introduction à la sécurité informatique

1.1 Introduction

L'explosion du trafic Internet et des activités numériques est un progrès incontestable. Mais il fait aussi courir des risques grandissants en matière de sécurité. Cette dernière n'est plus confinée uniquement au rôle de l'informaticien. Sa finalité sur le long terme est de maintenir la confiance des utilisateurs. La finalité sur le moyen terme est la cohérence de l'ensemble des systèmes. Sur le court terme, l'objectif est que chacun ait accès aux informations dont on a le droit.

1.2 Motivations

1.2.1 Certains faits

Que ce soit à l'´echelle d'une entreprise, d'une multinationale ou à plus petite échelle, la sécurité d'un système d'information, voire informatique prend plus ou moins d'importance selon la valeur que l'on confère à ces données. Dans cette section, un certain nombre de faits sont cités afin de montrer l'importance de la sécurité des systèmes informatiques :

- 97 % des réseaux d'entreprises présentent des signes d'activités suspectes, 82 % des entreprises dans le monde ont été victimes de cyberattaques et de pertes de données au cours de l'année 2019 ;
- Il y a trois millions de nouveaux malwares (programmes informatiques malveillants) qui apparaissent chaque jour (selon Symantec) ;
- Moins de 3 minutes sont nécessaires à une personne malveillante pour prendre le contrôle d'un objet connecté (Caméras de surveillance, imprimantes, thermostats intelligents) (selon ForeScout).
- Plus de 83 % de smartphones infectés au 2e semestre 2016, La plupart de ces malwares se propagent via le traditionnel (lien frauduleux) ou en téléchargeant une application malveillante.
- 5,6 millions de données personnelles (adresse mail, mot de passe, numéro de carte bancaire, etc.) sont piratées ou perdues chaque année (selon Gemalto), soit 65 vols de données par seconde.
- Google a supprimé 1,7 milliard de publicités mensongères, illégales ou trompeuses en 2016

- 1,22 million d'attaques par phishing (lien frauduleux) ont été enregistrées en 2016 (selon l'Anti-Phishing Working), soit 140 attaques de phishing par heure.
- Les particuliers deux fois plus infectés que les professionnels(selon Microsoft).

1.2.2 Effets

Les conséquences des cyberattaques sont :

- Perte ou mise en danger de la vie humaine ;
- Pertes financières ;
- Déni de service ;
- Utilisation ou abus non autorisés des systèmes informatiques ;
- Perte, changement et/ou altération des données ou logiciels ;
- Etc.

Quelques exemples :

- En mai 2017, le virus **WannaCry** a paralysé plus de 300 000 ordinateurs de sociétés multinationales et de services publics dans 150 pays. Les pertes économiques varient entre 4 et 8 milliards USD.
- En juin 2017 Le ransomware **NotPetya** s'est propagé plus vite que le virus WannaCry. Il a d'abord touché des banques, des aéroports et des structures gouvernementales en Ukraine. Il a ensuite frappé la société pétrolière russe Rosneft, l'allemand Beiersdorf (Nivéa), Auchan, le grand armateur Maersk, FedEx et Mondelez. La facture est estimée à 10 milliards USD, dont 3 milliards USD de pertes assurées.
- En 2018 Le groupe hôtelier Marriott International a subi un piratage massif. Suite à une faille de sécurité informatique, les données de 500 millions de clients ont été dérobées.
- Le 19 février 2019, une série d'attaques informatiques a visé des noms de domaine dans le monde. Les hackers ont attaqué des gouvernements, des services de renseignements ou de police, des compagnies aériennes, des sociétés pétrolières au Moyen-Orient et en Europe.
- En juillet 2019 Vol de données personnelles de 106 millions de clients de la banque américaine Capital One.

1.3 Concepts de la Sécurité

1.3.1 Définition de la sécurité

La sécurité informatique est l'ensemble des moyens techniques, organisationnels, juridiques et humains nécessaires à la mise en place de moyens visant à empêcher l'utilisation non autorisée, le mauvais usage, la modification ou le détournement d'un système.

La sécurité engendre généralement le déploiement de moyens techniques, mais également et surtout, de solutions de prévention, qui doivent absolument prendre en compte la formation et la sensibilisation de tous les acteurs du système. Des règles et de bonnes pratiques doivent être mises en place pour ne pas créer de brèches humaines. Ce sont les actifs d'une entreprise qui possèdent son capital intellectuel.

1.3.2 Principaux concepts de la sécurité informatique

La sécurité informatique utilise un vocabulaire bien défini. Pour bien comprendre la suite du cours, il est nécessaire de définir certains termes :

Les vulnérabilités : ce sont les failles de sécurité dans un ou plusieurs systèmes. Tout système vu dans sa globalité présente des vulnérabilités, qui peuvent être exploitables ou non.

Les attaques : elles représentent les moyens d'exploiter une vulnérabilité. Il peut y avoir plusieurs attaques pour une même vulnérabilité, mais toutes les vulnérabilités ne sont pas exploitables.

Les contre-mesures : ce sont les procédures ou techniques permettant de résoudre une vulnérabilité ou de contrer une attaque spécifique (auquel cas il peut exister d'autres attaques sur la même vulnérabilité).

Les menaces : ce sont des adversaires déterminés et capables de monter une attaque exploitant une vulnérabilité.

1.4 Objectifs de la sécurité informatique

La sécurité d'un système repose sur six grands principes :

1.4.1 Authentification

C'est de limiter l'accès qu'aux personnes autorisées. Il faut s'assurer de l'identité d'un utilisateur avant l'échange de données, en d'autres termes, l'identité d'un utilisateur doit être prouvée. Par exemple on peut utiliser un mot de passe, ou une méthode de défi basée sur une fonction cryptographique et un secret partagé.

1.4.2 Confidentialité

C'est la garantie que les données échangées ne sont compréhensibles que pour les entités qui partagent un même secret, souvent appelé association de sécurité (SA). Cette propriété implique la mise en œuvre d'algorithmes de chiffrements.

1.4.3 Intégrité

Il faut garantir à chaque instant que les données qui circulent sont bien celles que l'on croit, qu'il n'y a pas eu d'altération (volontaire ou non) au cours de la communication. L'intégrité des données doit valider l'intégralité des données, leur précision, l'authenticité et la validité. Le chiffrement évite les écoutes indiscrètes, mais il ne protège pas contre la modification des informations.

1.4.4 Non-répudiation

Une transaction ne peut être niée par aucun des correspondants. La non-répudiation de l'origine et de la réception des données prouve que les données ont bien été reçues. La non-répudiation empêche tant l'expéditeur que le receveur de nier avoir transmis ou reçu un message. Ainsi, lorsqu'un message est envoyé, le receveur peut prouver que le message a bien été envoyé par

l'expéditeur prétendu. De même, lorsqu'un message est reçu, l'expéditeur peut prouver que le message a bien été reçu par le receveur prétendu.

1.4.5 Disponibilité

Il faut s'assurer du bon fonctionnement du système, de l'accès à un service et aux ressources à n'importe quel moment. La disponibilité d'un équipement se mesure en divisant la durée durant laquelle cet équipement est opérationnel par la durée durant laquelle il aurait dû être opérationnel. De nombreuses attaques peuvent résulter en une perte ou une réduction de la disponibilité d'un service ou d'un système. Certaines de ces attaques sont susceptibles d'être l'objet de contre-mesures automatiques, telles que l'authentification et le chiffrement, alors que d'autres exigent une action humaine pour prévenir ou se rétablir de la perte de disponibilité des éléments d'un système.

1.4.6 Contrôle d'accès

Dans le contexte de la sécurité des réseaux, le contrôle d'accès est la faculté de limiter et de contrôler l'accès à des systèmes et des applications via des maillons de communications. Pour accomplir ce contrôle, chaque entité essayant d'obtenir un accès doit d'abord être authentifiée, ou s'authentifier, de telle sorte que les droits d'accès puissent être adaptés à son cas.

1.5 Menaces et attaques informatiques

1.5.1 Catégories d'attaques

Il existe quatre catégories d'attaques :

1.5.1.1 Interception

C'est une attaque portée à la confidentialité. Il peut s'agir d'une personne, d'un programme ou d'un ordinateur. Une écoute téléphonique dans le but de capturer des données sur un réseau, ou la copie non autorisée de fichiers ou de programmes.

1.5.1.2 Interruption

C'est une attaque portée à la disponibilité, elle consiste à rendre les données d'un système inaccessible. Cela implique par exemple la suppression de données, rendre l'accès à un serveur indisponible par une attaque de déni de service, la destruction d'une pièce matérielle (tel un disque dur), la coupure d'une ligne de communication, ou la mise hors service d'un système de gestion de fichiers.

1.5.1.3 Modification

Il s'agit d'une attaque portée à l'intégrité. Changer des valeurs dans un fichier de données, altérer un programme de façon à bouleverser son comportement ou modifier le contenu de messages transmis sur un réseau.

1.5.1.4 Fabrication

C'est une attaque portée à l'authenticité. Il peut s'agir de l'insertion de faux messages dans un réseau ou l'ajout d'enregistrements à un fichier par une tierce partie non autorisée.

1.5.2 Scénarios d'attaques

Les attaques peuvent être classées en 2 types de scénarios :

1.5.2.1 Attaques passives

Consistent à écouter sans modifier les données ou le fonctionnement du réseau. Elles sont généralement indétectables, mais une prévention est possible. Écoutes indiscrètes ou surveillance de transmissions sont des attaques de nature passive. Le but de l'adversaire est d'obtenir une information qui a été transmise. Ces attaques passives sont la capture du contenu d'un message et l'analyse de trafic.

1.5.2.2 Attaques actives

Ces attaques impliquent certaines modifications du flot de données ou la création d'un flot frauduleux ; elles peuvent être subdivisées en quatre catégories : mascarade, rejeu, modification de messages et déni de service.

Une mascarade a lieu lorsqu'une entité prétend être une autre entité ;

Le rejeu implique la capture passive de données et leur retransmission ultérieure en vue de produire un effet non autorisé ;

La modification de messages signifie que certaines portions d'un message légitime sont altérées ou que les messages sont retardés ou réorganisés ;

Le déni de service empêche l'utilisation normale ou la gestion de fonctionnalités du système.

1.5.3 Techniques d'attaques

Dans cette section nous allons présenter certaines techniques d'attaques les plus connues.

1.5.3.1 Porte dérobée (*backdoor*)

C'est un point d'entrée dans un programme ou un système plus ou moins secret. Généralement une sécurité pour débloquer un code d'accès perdu ou pour le débogage. C'est aussi le point d'entrée des hackers. Ils peuvent même les créer pour les utiliser ultérieurement.

1.5.3.2 Reniflage (*sniffing*)

C'est l'écoute d'une ligne de transmission par laquelle transitent des données pour les récupérer à la volée. Cette technique peut être utilisée à l'interne pour le débogage ou de manière abusive par un hacker cherchant, par exemple, à procurer un mot de passe. Elle Vise surtout à intercepter les données non chiffrées, comme dans certains réseaux (non commutés, reliés par (hub)ou câbles coaxiaux), l'ensemble des messages est transmis à tous.

1.5.3.3 Mystification (*spoofing*)

C'est une technique d'intrusion qui consiste à envoyer à un serveur des paquets qui semblent provenir d'une adresse IP connue par le pare-feu.

1.5.3.4 Attaque par rebond (*bounce attack*)

Elle est menée via un autre ordinateur qui se retrouve complice involontaire. Cet ordinateur expédie des messages d'attaque à la victime en masquant l'identité du hacker.

1.5.3.5 Attaque de l'homme du milieu (*man-in-the-middle*)

Le hacker se place entre deux ordinateurs et se fait passer pour un afin d'obtenir le mot de passe de l'autre. Il peut alors se retourner contre le premier avec un mot de passe valide pour l'attaquer.

1.5.3.6 Déni de service (*denial of service*)

Une attaque cherchant à rendre un serveur hors service en le submergeant de trafic inutile. Par exemple, un serveur entièrement occupé à répondre à de fausses requêtes de connexion. Des machines peuvent être à l'origine de l'attaque généralement à l'insu de leur propriétaire.

1.5.3.7 Trébuchage sans fil (*war-driving)*

Dans le cas des réseaux sans fil. Consiste à circuler dans la ville avec un portable ou un assistant numérique personnel (PDA)pour repérer et pénétrer les réseaux locaux non protégés.

1.5.3.8 Bombe logique

Une bombe logique est une fonction, cachée dans un programme en apparence honnête, utile ou agréable, qui se déclenchera à retardement, lorsque aura atteint une certaine date, ou lors d'un certain événement. Cette fonction produira alors des actions indésirées, voire nuisibles.

1.5.3.9 Spamming

Le spam, courriel indésirable est une communication électronique non sollicitée, en premier lieu via le courrier électronique. Il s'agit en général d'envois en grande quantité effectués à des fins publicitaires ou de déni de service. Parmi les attaques de spamming, on peut citer :

Canular (*hoax*) : Il peut s'agir de courriels, de messages publiés sur des forums ou les réseaux sociaux et dont les contenus cherchent à créer l'inquiétude, l'indignation ou au contraire l'approbation. Ce n'est pas un malware, mais le but étant que l'information soit suffisamment forte pour inciter l'internaute à la relayer à son entourage : par exemple, l'existence d'un nouveau virus informatique redoutable, révélation d'une information (cachée)au grand public, vidéo émouvante, scandale financier, etc.

Hameçonnage (*Phishing*) : technique frauduleuse utilisée par les hackers pour récupérer des informations (généralement bancaires) auprès d'internautes. La technique consiste à faire croire à la victime qu'elle s'adresse à un tiers de confiance (banque, administration, etc.) afin de lui soutirer des renseignements personnels : mot de passe, numéro de carte de crédit, numéro ou photocopie de la carte nationale d'identité, date de naissance, etc. En effet, le plus souvent, une copie exacte d'un site Internet est réalisée dans l'optique de faire croire à la victime qu'elle se trouve sur le site Internet officiel où elle pensait se connecter.

Arnaque : Technique utilisée par des personnes (escrocs), ils vous promettent la fortune d'un proche, ou celle de l'avocat d'un millionnaire décédé, en échange d'un paiement initial. L'histoire change légèrement lorsque l'escroc se fait passer pour une personne célèbre qui connaît certaines difficultés. Ils promettent aux victimes une importante récompense si elles acceptent d'aider ce pauvre millionnaire à retirer les fonds bloqués sur plusieurs comptes bancaires. Pour ce faire, les victimes doivent, bien évidemment, d'abord envoyer certaines informations détaillées les concernant (passeport, données du compte, etc.), puis réaliser le transfert d'une modeste somme d'argent pour couvrir les frais d'administration.

1.5.4 Motivation, profiles des attaquants (Hackers)

1.5.4.1 Motivation des hackers

La définition du terme hacker, qui est assez large. À l'origine, "hacker" est un mot anglais qui veut dire "bricoleur" ou encore "bidouilleur".

En informatique, ce terme est utilisé pour définir les programmeurs débrouillards, avec des connaissances techniques élevées. Ces programmeurs sont avant tout passionnés par ce qu'ils font, ils ne se posent pas de limites pour la connaissance ou pour assouvir leur curiosité.

Les hackers sont également capables de détourner un objet ou un logiciel de son fonctionnement originel. Ils utilisent leur savoir pour découvrir les choses auxquelles ils ne sont pas censés avoir accès. Mais la communauté des hackers va également au-delà de la connaissance technique. Être un hacker correspond davantage à un état d'esprit plus qu'au fait de programmer.

Ainsi, les hackers sont généralement des personnes cultivées qui connaissent à la fois l'historique de leur statut, les grands acteurs du mouvement, qui se tiennent informées de tout ce qui s'apparente à leur domaine et qui ont soif de connaissance.

1.5.4.2 Capacités des attaquants

Les capacités des attaquants peuvent être comme suite :

- Transmission de messages sans capacité d'écoute (IP spoofing, etc.) ;
- Écoute et transmission de messages ;
- Écoute et perturbation des communications (blocage de paquets, DoS) ;
- Écoute, perturbation et transmissions de messages ;
- Écoute et relai de messages (attacks type man-in-the-middle).
-

1.5.4.3 Types d'attaquants

On distingue différents types d'attaquants (*hacker*) :

Les chapeaux noirs (*black hats*) : Généralement, ces hackers ne respectent pas la loi, ils pénètrent par effraction dans les systèmes dans un intérêt qui n'est pas celui des propriétaires du réseau. L'intérêt y est personnel, généralement financier, en tout cas le but est nuisible à la personne (physique ou morale) visée. Ces hackers sont d'ailleurs plus généralement appelés des *crackers*, ces derniers sont par exemple les créateurs de virus, de chevaux de Troie ou de logiciels espions.

Les chapeaux blancs (*white hats*) : Techniquement, l'action menée par les chapeaux blancs est très proche de celle des chapeaux noirs. Cependant, elle se différencie par le but ou la finalité. En effet, les chapeaux blancs ont plutôt comme ambition d'aider à la sécurisation du système, sans en tirer profit de manière illicite. Les chapeaux blancs bricolent et testent les systèmes d'information pour découvrir les vulnérabilités pas encore connues ou non publiques. La technique employée est la même que pour un hacker chapeau noir.

Les chapeaux gris (*grey hats*) : Un chapeau gris est un peu un hybride du chapeau blanc et du chapeau noir. Il s'agit d'un hacker compétent, qui agit parfois avec l'esprit d'un Un chapeau blanc, parfois avec celui d'un Un chapeau noir. Son intention n'est pas forcément mauvaise, mais il commet cependant occasionnellement un délit. Beaucoup de hackers qui se disent Un chapeau blanc s'apparentent en réalité plus à des Un chapeau gris, dans le sens où ils ne révèlent pas toujours leurs découvertes et en profitent à des fins personnelles.

Les (*script kiddies*) : Dans le problème lié à la publication sur Internet des vulnérabilités découvertes, on trouve l'un des éléments clés de la discorde, les script kiddies, autrement dit de jeunes hackers néophytes. Ces individus récupèrent les exploits laissés par les white hats sur les outils publics et les exécutent sur des machines, sans aucune connaissance, dans le but de provoquer des pannes volontaires.

Généralement un *script kiddie* est un jeune adolescent, pénétrant par effraction dans un système, après avoir étudié/lu dans des livres ou sur Internet quelques documentations de base sur le sujet de la sécurité informatique. Le *script kiddie* n'a aucune notion de l'éthique d'un hacker, il agit par vantardise auprès de ses copains, il n'est pas rare par exemple qu'il demande à "pirater un compte de messagerie instantanée".

Les hackers universitaires : Ce sont des hackers libres, que l'on associe au mouvement Open Source du logiciel libre, comme Richard Matthew Stallman, le fondateur du projet GNU. Cette définition du hacker libre est apparue au MIT, le Massachusetts Institute of Technology.

Le hacker est alors défini comme quelqu'un qui partage sa connaissance avec autrui, sur le fonctionnement d'un système, des ordinateurs et des réseaux. Ces hackers prônent la pensée selon laquelle l'information est libre et n'appartient à personne. Ainsi, toute nouvelle connaissance se veut d'être partagée avec tout le monde.

1.5.5 Les menaces (*malware*)

Le terme *malware* (fusion de (*malicious*) pour malveillant et de (*software*) pour programme/logiciel) est désormais utilisé pour désigner tout programme malveillant présent sur un ordinateur ou un appareil mobile.

Ces programmes sont installés à l'insu des utilisateurs et peuvent générer de nombreux effets indésirables, comme la paralysie des performances informatiques, l'exploitation des données personnelles de votre système, la suppression des données, voire même le dysfonctionnement du matériel contrôlé par ordinateur. Les hackers développent des moyens plus sophistiqués pour infiltrer les systèmes des utilisateurs, entraînant ainsi une explosion du marché des programmes malveillants. Quelques-uns des programmes malveillants les plus couramment observés seront présentés ci-dessous :

1.5.5.1 Virus informatiques

Les virus informatiques ont acquis ce nom en raison de leur capacité à infecter plusieurs fichiers sur un ordinateur. Ils se propagent sur les autres machines lorsque des fichiers infectés sont envoyés par e-mail ou lorsque des utilisateurs les transportent sur des supports physiques tels que des clés USB ou des disquettes (au début).

Selon le National *Institute of Standards and Technology (NIST)*, le premier virus informatique, appelé (*Brain*), a été développé en 1986. Lassés de voir les clients pirater les logiciels de leur magasin, deux frères prétendent avoir conçu le virus permettant d'infecter le secteur d'amorçage des disquettes des voleurs, propageant ainsi le virus lors de leur copie.

1.5.5.2 Vers(*worm*)

Contrairement aux virus, les vers ne nécessitent pas d'intervention humaine pour se propager et infecter les ordinateurs : il s'agit d'un programme capable d'utiliser des réseaux informatiques pour infecter les autres machines connectées sans l'aide des utilisateurs. En exploitant les vulnérabilités des réseaux telles que les failles des programmes de messagerie électronique, les vers peuvent se répliquer des milliers de fois en vue d'infecter de nouveaux systèmes dans lesquels le processus se reproduira. Bien que de nombreux vers utilisent simplement les ressources système, réduisant ainsi les performances, la plupart d'entre eux contiennent des (charges utiles) malveillantes conçues pour dérober ou supprimer des fichiers.

1.5.5.3 Adware

Les *adware* représentent l'une des nuisances les plus couramment rencontrées en ligne. Les programmes envoient automatiquement des publicités aux ordinateurs hôtes. Les types de programmes adware courants incluent des publicités contextuelles sur les pages Web et des publicités intégrées au programme qui accompagnent bien souvent un logiciel (gratuit). Bien que certains adware soient relativement sans danger, d'autres variantes utilisent des outils de suivi permettant de récupérer des informations sur votre site ou sur votre historique de navigation et affichent des publicités ciblées sur votre écran.

Le programme adware étant installé avec le consentement des personnes après les avoir informés, de tels programmes ne peuvent donc pas être appelés programmes malveillants : ils sont généralement identifiés en tant que (programmes potentiellement indésirables).

1.5.5.4 Logiciels espions (*Spaywares*)

Un logiciel espion agit comme son nom l'indique, à savoir, espionner ce que vous faites sur votre ordinateur. Il recueille des données telles que les saisies clavier, vos habitudes de navigation et

vos informations de connexion qui sont alors envoyées à des tiers, généralement des cybercriminels. Il peut également modifier des paramètres de sécurité spécifiques sur votre ordinateur ou interférer avec les connexions réseau.

1.5.5.5 Ransomware

Les *ransomware* infectent votre ordinateur, puis chiffrent des données sensibles telles que des documents personnels ou des photos, puis demandent une rançon pour les récupérer. Si vous refusez de payer, les données sont supprimées. Certaines variantes de ransomware verrouillent l'accès à votre ordinateur. Ils peuvent prétendre provenir d'organismes légitimes chargés de faire appliquer la loi et suggérer que vous vous êtes fait prendre pour avoir mal agit.

1.5.5.6 Robots

Les robots sont des programmes conçus pour exécuter automatiquement des opérations spécifiques. Ils sont utilisés à de nombreuses fins légales, mais ont été redéfinis comme un type de programme malveillant. Une fois dans l'ordinateur, les robots peuvent faire en sorte que la machine exécute des commandes spécifiques sans que l'utilisateur ne les autorise ou n'en soit informé. Les hackers informatiques peuvent également tenter d'infecter plusieurs ordinateurs avec le même robot afin de créer un (*botnet*) (contraction des termes (*robot*) et (*network*) (réseau), qui peuvent alors être utilisés pour gérer à distance des ordinateurs infectés (pour dérober des données sensibles, espionner les activités de la victime, distribuer automatiquement des spams ou lancer des attaques DDoS (*A distributed denial-of-service*) dévastatrices sur des réseaux informatiques).

1.5.5.7 Botnets

Les botnets sont des réseaux d'ordinateurs infectés par un agent de botnet qui sont sous le contrôle caché d'un tiers. Ils sont utilisés pour exécuter diverses commandes commandées par l'attaquant. Les utilisations les plus courantes des botnets sont des opérations criminelles qui nécessitent des ressources distribuées, telles que des attaques DDoS sur des cibles sélectionnées, des campagnes de spam et la fraude aux clics. Souvent, l'agent de botnet reçoit l'ordre de télécharger et d'installer des charges utiles supplémentaires ou de voler des données de l'ordinateur local.

1.5.5.8 Rootkits

Les *rootkits* autorisent un tiers à accéder ou contrôler à distance d'un ordinateur. Ces programmes permettent aux professionnels de l'informatique de résoudre à distance des problèmes de réseau, mais ils peuvent également devenir malveillants : une fois installés sur votre ordinateur, les hackers peuvent prendre le contrôle de votre machine pour dérober des données ou installer d'autres composants du programme malveillant. Les rootkits sont conçus pour passer inaperçus et masquer activement leur présence. La détection de ce type de code malveillant nécessite la surveillance manuelle de comportements inhabituels ainsi que l'application régulière de correctifs sur votre système d'exploitation et vos logiciels afin d'éliminer les chemins d'accès potentiels d'infection.

1.5.5.9 Chevaux de Troie (*Trojans*)

Ces programmes se fondent en se faisant passer pour des fichiers ou des logiciels légitimes. Une fois téléchargés et installés, ils modifient un ordinateur et conduisent des activités malveillantes, à l'insu de la victime.

1.5.5.10 Minage de cryptomonnaie malveillant (*cryptojacking*)

Le *cryptojacking* est une arnaque qui utilise les appareils des particuliers (ordinateurs, smartphones, tablettes ou même des serveurs), sans leur consentement ou sans qu'ils le sachent, pour miner en secret la cryptomonnaie sur le compte de la victime. Au lieu de créer un ordinateur de minage de cryptomonnaie dédié, les hackers utilisent le cryptojacking pour voler des ressources informatiques sur les appareils de leurs victimes. Quand vous ajoutez toutes ces ressources, les hackers peuvent participer à des opérations de minage sophistiquées sans payer les frais associés.

1.5.5.11 Failles(Bugs)

Les bugs d'un code logiciel ne correspondent pas à un type de programme malveillant, mais à des erreurs commises par un programmeur. Ils peuvent avoir des conséquences néfastes sur votre ordinateur : blocage, panne ou réduction des performances. Les bugs de sécurité, quant à eux, permettent aisément aux hackers de passer outre vos défenses et d'infecter votre machine. Bien qu'un meilleur contrôle de la sécurité côté développeur facilite l'élimination des bugs, il est également essentiel d'appliquer des correctifs qui corrigent les bugs spécifiques en circulation.

1.6 Mécanismes de défense

1.6.1 Authentification

L'authentification consiste à identifier et à vérifier l'identité des utilisateurs, c'est-à-dire vérifier l'association entre l'utilisateur et son identité. L'identité est une information unique associée à l'utilisateur, et connue du système réalisant l'authentification et de l'utilisateur. L'authentification est requise pour s'assurer qu'une application ou un utilisateur est en droit ou non de communiquer avec une application. Un service d'authentification repose sur deux composantes :

- L'identification dont le rôle est de définir les identités des utilisateurs ;
- L'authentification permettant de vérifier les identités présumées des utilisateurs.

1.6.2 Contrôle d'accès

Le contrôle d'accès est la gestion des autorisations d'accès à des ressources. Une autorisation consiste à gérer et à vérifier les droits d'accès, en fonction des règles spécifiées dans la politique de sécurité. On dit qu'un sujet (entité qui demande l'accès, dite aussi entité active) possède un droit d'accès sur un objet (entité à laquelle le sujet souhaite accéder, dite aussi entité passive) si et seulement s'il est autorisé à effectuer la fonction d'accès correspondante sur cet objet.

1.6.3 Stéganographies

La stéganographie est l'art de cacher un message secret au sein d'un autre message porteur (texte, image, son, vidéo...) de caractère anodin, de sorte que l'existence même du secret en soit dissimulée. Alors qu'avec le chiffrement, la sécurité repose sur le fait que le message chiffré soit incompréhensible pour les personnes non autorisées, avec la stéganographie, la sécurité repose sur le fait que la présence même d'un message secret ne sera sans doute pas soupçonnée et détectée.

1.6.4 Chiffrement

C'est l'ensemble des techniques permettant de chiffrer des messages, c'est-à-dire de les rendre incompréhensibles sans une action spécifique. Le message initial est appelé message en clair et, après chiffrement, message chiffré ou cryptogramme. Le chiffrement et le déchiffrement sont réalisés principalement à partir d'algorithmes, en utilisant des clés secrètes ou publiques. Les techniques de chiffrement sont essentiellement scindées en deux, notamment :

1.6.4.1 Le chiffrement symétrique

il consiste à utiliser la même clé pour chiffrer (crypter) et déchiffrer (décrypter) un message. Il est important de savoir que le cryptage asymétrique est moins sécurisé, du fait que c'est la seule clé qui est échangée entre les deux entités communicantes.

1.6.4.2 Le chiffrement asymétrique

Dans ce type de chiffrement, les clés existent par paire, c'est-à-dire une clé publique pour le chiffrer, et une clé privée (dite secrète) pour déchiffrer le message, et seul l'utilisateur à qui le message est destiné possède la clé secrète pour déchiffrer le message. Ce mécanisme est plus sécurisé que le chiffrement symétrique

1.6.5 Signature numérique

Une signature numérique est un mécanisme de cryptographie utilisé pour vérifier l'authenticité et l'intégrité de données numériques. Nous pouvons considérer cela comme une version numérique des signatures manuscrites ordinaires, mais avec des niveaux plus élevés de complexité et de sécurité. Pour simplifier, nous pouvons décrire une signature numérique comme un code rattaché à un message ou un document. Après avoir été généré, le code sert de preuve que le message n'ait été trafiqué d'aucune sorte entre l'expéditeur et le destinataire. Des fonctions à sens unique (encore dénommées fonction de hachage) telles que MD5 (16 octets) ou SHA1 (20 octets) réalisent ce service.

1.6.6 Fonctions de hachage

Le Hachage constitue l'un des éléments principaux d'un système de signature numérique. Le processus de hachage implique de transformer des données de n'importe quelle taille en une sortie avec une taille prédéterminée. On réalise une telle chose avec un type particulier d'algorithme connu sous le nom de fonction de hachage (à sens unique). La sortie générée par une fonction de hachage est connue sous le nom de valeur de hachage ou encore d'empreinte.

Quand elle est combinée avec de la cryptographie, la fonction de hachage cryptographique peut être utilisée pour générer une valeur de hachage (empreinte) qui agit comme une empreinte numérique unique. Cela signifie que tout changement dans les données d'entrée (message) entraînerait une sortie complètement différente (valeur de hachage). C'est la raison pour laquelle les fonctions de hachage cryptographique sont largement utilisées pour vérifier l'authenticité de données numériques.

1.6.7 Certification

Un certificat numérique peut être vu comme une carte d'identité numérique, les certificats peuvent servir à l'authentification des utilisateurs à un système d'information, à contrôler

l'accès à certaines applications ou à certaines données, notamment des publications en ligne. L'utilisation de ces certificats électroniques pour des applications de signature électronique est possible.

1.6.8 Antivirus

Les antivirus sont des logiciels conçus pour identifier, neutraliser et éliminer des logiciels malveillants. Il ne protège pas contre un intrus qui emploie un logiciel légitime, ou contre un utilisateur légitime qui accède à une ressource alors qu'il n'est pas autorisé à le faire.

1.6.9 Pare-feu

Un pare-feu peut être considéré comme une approche standard qui protège les ressources informatiques locales contre les menaces externes. Un pare-feu est conçu pour filtrer les paquets IP provenant du réseau externe vers le réseau local. C'est aussi un moyen efficace de protéger le système local ainsi que le réseau, et vous pouvez accéder simultanément à Internet ou à un réseau étendu. Il n'empêche pas un attaquant d'utiliser une connexion autorisée pour attaquer le système. Il ne protège pas contre une attaque venant du réseau intérieur (qui ne le traverse pas).

1.6.10 Système de détection d'intrusion

Un système de détection d'intrusion (IDS : *Intrusion détection System*) est un mécanisme destiné à repérer des activités anormales ou suspectes sur la cible analysée (un réseau ou un hôte). Il permet ainsi d'avoir une connaissance sur les tentatives réussies comme échouées des intrusions.

1.6.11 Journalisation (*logs*)

Désigne l'enregistrement séquentiel dans un fichier (ou une base de données) de tous les événements affectant un processus particulier (application, activité d'un réseau informatique, etc.). Le journal (*log*), désigne alors le fichier contenant ces enregistrements. Généralement datés et classés par ordre chronologique, ces derniers permettent d'analyser pas à pas l'activité interne du processus et ses interactions avec son environnement.

1.7 Conclusion

On mesure la sécurité d'un système entier à la sécurité du maillon le plus faible. Ainsi, si tout un système est sécurisé techniquement, mais que le facteur humain souvent mis en cause est défaillant c'est toute la sécurité du système qui est remise en cause. Dans un contexte global, la sécurité doit être assurée :

- Au niveau utilisateur : les acteurs doivent comprendre l'importance de leur position ;
- Au niveau des technologies utilisées : elles doivent être sûres et ne pas présenter de failles ;
- Au niveau des données en elles-mêmes : avec une bonne gestion des droits d'accès (authentification et contrôle) l'utilisateur doit posséder uniquement les droits qui lui sont nécessaires) ;
- Au niveau physique (accès à l'infrastructure) au matériel, etc.) : rien ne sert de sécuriser un système logiquement si matériellement l'accès à la salle des machines n'est pas sécurisé ;